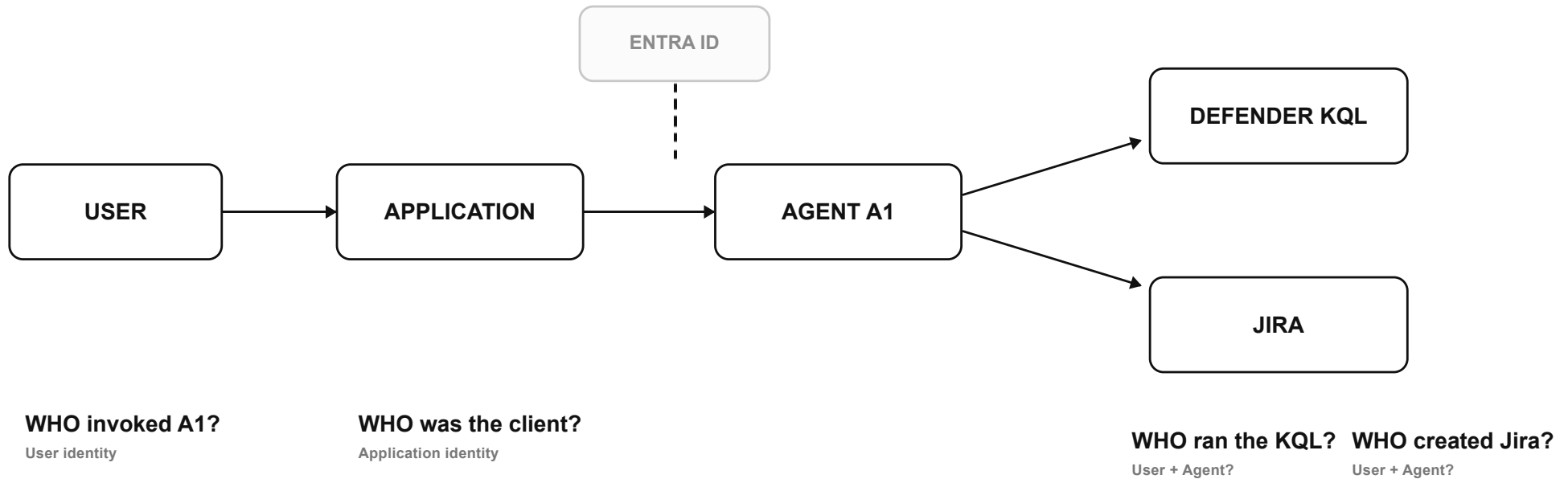
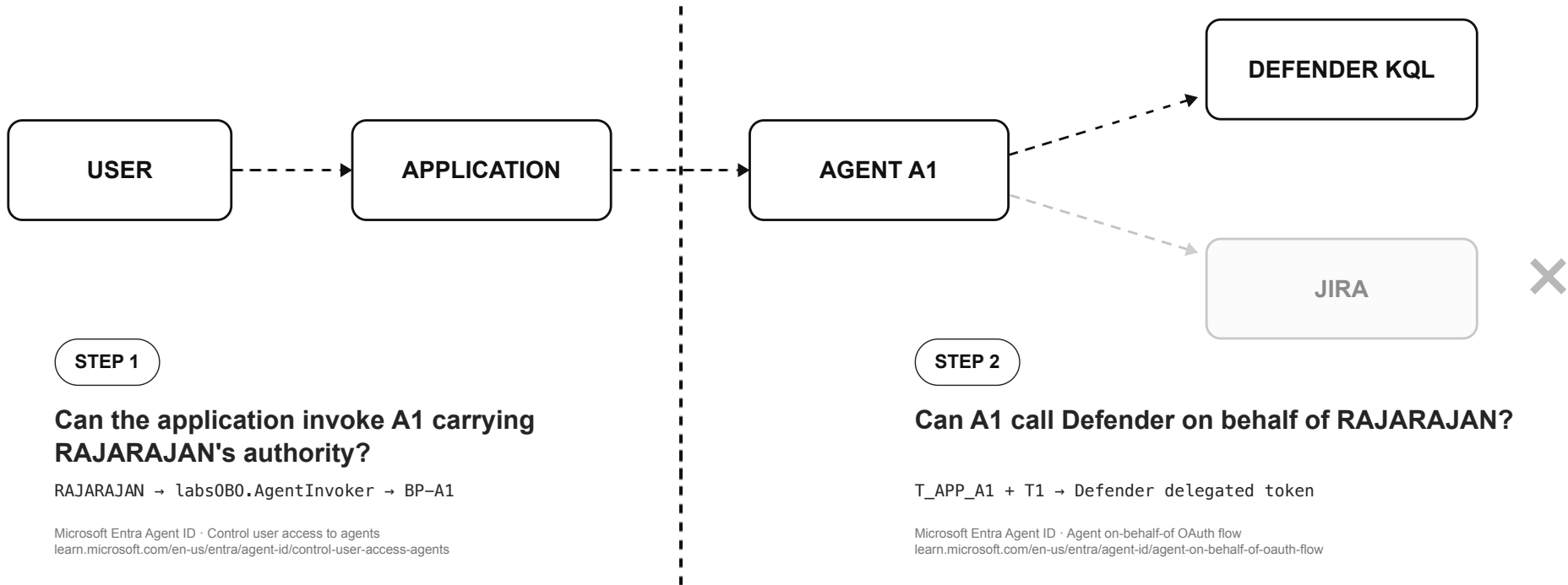


# The attribution gap



If two users run two KQL queries through the same agent, how do we prove which user triggered which query — and which downstream action belongs to whom?

## Two steps



# STEP 1 · Make the user → agent relationship explicit



Microsoft

rajarajan@fmrcom

### Permissions requested (1 of 2 apps)

labsOBO-calling-app

[App info](#)

**This application is not published by Microsoft.**

This app would like to:

- Invoke labsOBO Agent A1 on your behalf (labsOBO-agent1-blueprint)  
Allows the app to invoke labsOBO Agent A1 on your behalf.  
This is a permission requested to access your data in Moring AI.
- View your basic profile  
Allows the app to see your basic profile (e.g., name, picture, user name, email address)  
This is a permission requested to access your data in Moring AI.
- Maintain access to data you have given it access to  
Allows the app to see and update the data you gave it access to, even when you are not currently using the app. This does not give the app any additional permissions.

- 1

**Deploy A1**  
AgentCore runtime
- 2

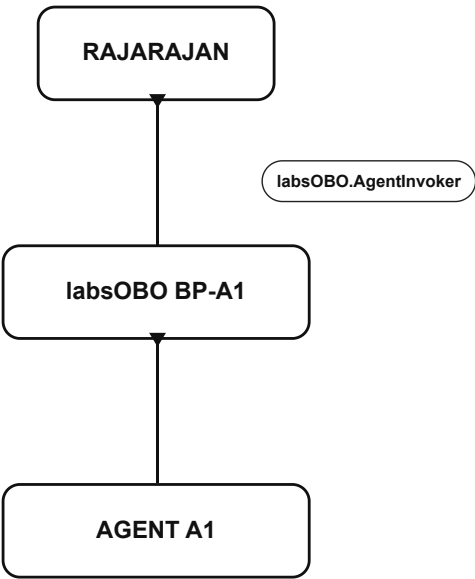
**Create Blueprint**  
labsOBO-agent1-blueprint
- 3

**Expose API**  
labsOBO\_access\_agent
- 4

**Create App Role**  
labsOBO.AgentInvoker
- 5

**Assign User**  
RAJARAJAN → AgentInvoker → BP-A1
- 6

**Enforce assignment**  
appRoleAssignmentRequired = true

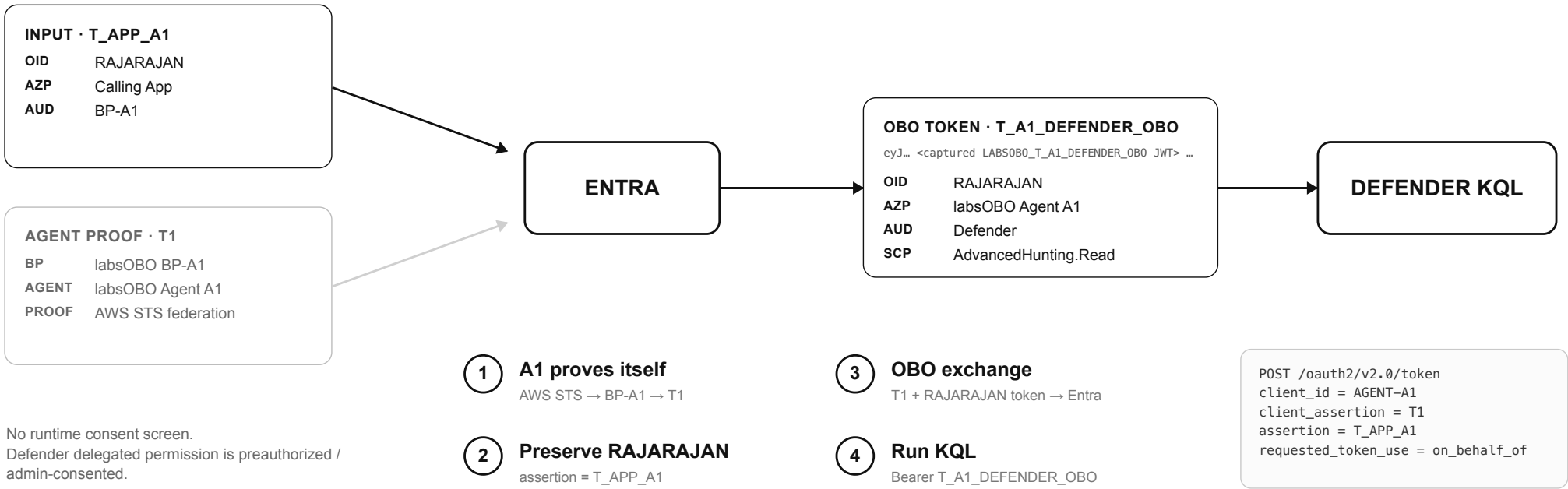


Consent ≠ entitlement    App asks for delegated API access.  
Assignment decides who may invoke A1.

| DISSECTED ACCESS TOKEN · WHAT EACH CLAIM PROVES |                                                                                                 |                                  |   |
|-------------------------------------------------|-------------------------------------------------------------------------------------------------|----------------------------------|---|
| claim                                           | value · meaning                                                                                 | expected                         |   |
| oid                                             | 2faa25c9-590d-4723-aebb-f39f819ce489<br><small>Which human? (the user object id)</small>        | RAJARAJAN                        | ✓ |
| azp                                             | 05d1bf77-a2e4-4c1c-9ef1-31dff291dd45<br><small>Which OAuth client asked for this token?</small> | APP (labsOBO-calling-app)        | ✓ |
| aud                                             | 5e5c2e3c-35b8-4817-8dc9-96b09adb6865<br><small>Which agent API boundary is it for?</small>      | BP-A1 (labsOBO-agent1-blueprint) | ✓ |

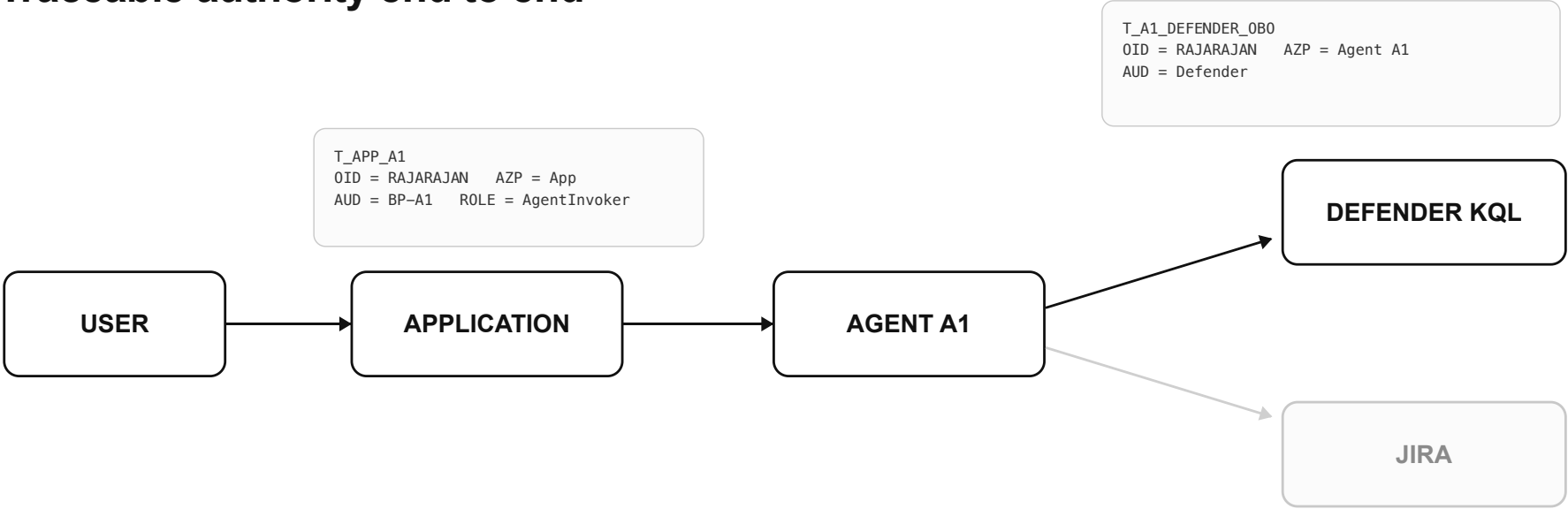
# STEP 2 · Preserve RAJARAJAN while A1 calls Defender

Agent identity becomes the actor. RAJARAJAN remains the subject.



**RAJARAJAN preserved. Actor changed: APP → A1.**

# Traceable authority end to end



INVOCATION

**RAJARAJAN → A1**

OID · AZP · AUD · ROLE

KQL

**RAJARAJAN + A1**

Subject preserved · actor changed

JIRA

**RAJARAJAN + A1 + workflow**